

Project 1: Developing a Risk Management Plan

Cole Dombrowski - MISY 5325

1. Organizational Context

Operating Environment

SCHN operates active healthcare facilities where patient information is shared between diagnostic areas, testing stations, and administrative offices. Since these systems support daily patient care, security measures need to protect information without making it harder for staff to access what they need in order to perform their job functions.

Resource Constraints

SCHN works with a limited annual budget, so technology/security improvements need to be justified to the Chief Financial Officer. Cost-Benefit Analysis' can also be used to determine whether a security improvement is worth the cost.

Infrastructure Layout

SCHN's systems are spread across workstations, internal networks, clinical facilities, and remote access connections. Security controls need to protect these systems while still allowing clinicians to quickly access patient information when providing care.

2. Purpose and Scope of the Risk Management Plan

The purpose of this Risk Management Plan is to create a consistent process for identifying, evaluating, and monitoring security risks without unnecessarily disrupting patient care. The plan covers SCHN's workstations, LAN/WAN connections, remote access, and the main facilities and

systems that handle patient information. It does not include detailed hardware lists, individual application source code reviews, or specific budget amounts.

3. Risk Environment

Technology Risks

- Unpatched clinical software, outdated systems, and limited network monitoring could give attackers an opportunity to access SCHN's systems.

People & Process Risks

- Employee mistakes, incorrect system settings, and phishing attacks could lead to unauthorized access/loss of patient information.

Environmental & Third-Party Risks

- Outside vendors can also create security risks, whereas events such as severe weather or power outages could take systems offline.
-

4. Risk Management Approach

SCHN will identify common threats and vulnerabilities and group them into major risk categories. Each risk can be documented using simple "if/then" statements to explain what could happen and why. The risks will then be evaluated based on their likelihood, potential impact, and

the associated cost of addressing them. This allows SCHN to focus its resources on the risks that could cause the most damage instead of trying to eliminate every possible risk. Also, security actions will be documented in a plan of action and milestones.

5. Roles and Responsibilities

Executive Leadership and Board

Executive leadership and the board will make final decisions on the major risks and approve the security spending. Their involvement is important because they are responsible for making decisions that affect the organization as a whole.

IT Support Department Head

The IT Support Department Head will oversee the technical work, track vulnerabilities, manage the network, and estimate the cost of security improvements. Their involvement is important because they understand SCHN's technology and security needs.

Clinical and Operations Leaders

Clinical and operations leaders will help determine which systems are most important for patient care and make sure security controls do not interfere with daily work.

Staff Members

Staff members will follow security policies and complete required security training. Their involvement is important because they use SCHN's systems every day and play a role in keeping them secure.

6. Compliance Considerations

SCHN needs to follow several requirements when it comes to protecting its systems and information. HIPAA is important because SCHN handles protected health information. This means the organization needs to have reasonable security measures in place to prevent patient information from being accessed, lost, or shared without improper authorization. Which includes things like user access controls, authentication, encryption, and proper handling of patient records.

PCI DSS applies to systems that handle credit and debit card information. SCHN needs to protect this information with basic security controls such as firewalls, limited access, and network separation where needed.

SCHN also needs to keep track of known security problems and take steps to address them, as documenting these issues helps management make informed decisions and shows that the organization is taking its responsibility to protect their patient/customer's information.

7. Preliminary Assets and Activities

Hardware

- Servers
- Firewalls
- Routers
- Workstations
- Clinical equipment

Software

- Electronic Health Record systems
- Billing systems
- Scheduling applications

Data

- Patient medical records
- Financial information
- Employee PII
- System logs

Core Activities

- Patient intake
- Clinical diagnostics
- Prescription processing
- Emergency services

- Billing
-

8. Management Summary

SCHN must take a practical approach to cybersecurity that protects its most important systems without making patient care harder. Since the organization has a limited budget, it cannot address every risk at the same level. It should focus on the risks that are most likely to cause serious problems. Systems such as EHRs, clinical systems, and payment networks should be given higher priority because problems with these systems could have a direct effect on SCHN's daily operations.

A clear risk management process will also help SCHN keep track of security issues and decide where improvements are needed. This leads to reductions in downtime, protecting patient information, and keeping important systems available.

References:

- Gibson, D., & Igonor, A. (2020). *Managing Risk in Information Systems* (3rd ed.). Jones & Bartlett Learning.